AppSec Debugging Runbook — Ten Common Student-App Vulnerabilities

Issued: 2026-10-06 | Use only on authorized Semester environments and accounts. Do not test institutional systems or production destructively without explicit written approval.

#	Vulnerability	Student-app failure mode	Safe validation	Primary fix	Regression proof
1	SQL injection (SQLi)	Search/filter/import value changes query meaning	Use harmless metacharacter fixtures against staging; review query construction	Parameterized queries/typed query builders; no string-concatenated SQL	Values remain data; query plan/action unchanged
2	Cross-site scripting (XSS)	Profile, message, course note, or admin content executes script	Use an inert marker and approved harmless test payload in staging	Contextual output encoding; safe DOM APIs; sanitize permitted rich HTML; CSP defense-in-depth	Marker renders as text in stored/reflected/DOM paths
3	RLS bypass / BOLA	Student A reads or changes B's record or a different school's record	Use separate synthetic users/tenants, direct API/RPC/storage requests	Correct RLS/grants plus server-side resource/tenant authorization	A cannot see/change B or T2 across all paths
4	Broken role escalation	User changes role, grant, owner, or approval field	Attempt controlled self-grant/owner-change fixture	Server-owned authorization fields; capability checks; narrow DB grants/RLS	No role/grant/ownership mutation occurs
5	JWT/session flaws	Expired, forged, stolen, or revoked session retains access	Test expired/wrong issuer/audience and post-revocation session in staging	Validate token claims; short/appropriate lifetimes; re-auth/revocation design; secure storage	All invalid/revoked contexts denied within documented bound
6	IDOR in exports/files	Guessed document/export ID or signed URL reveals another user's material	Cross-user/tenant object and export tests with fixtures	Authorize each object operation; private buckets; bounded signed URLs; scoped cache keys	No foreign file/record bytes or metadata return

#	Vulnerability	Student-app failure mode	Safe validation	Primary fix	Regression proof
7	Unsafe file upload	Script/polyglot/oversized file becomes publicly available or processed dangerously	Upload benign mismatched-type and large test fixtures	Allowlist type/size; inspect content; private storage; quarantine/scan; safe disposition	Invalid files rejected; valid files remain correctly scoped
8	CSRF / cross-origin writes	Attacker origin changes a logged-in user's settings	Controlled cross-origin request in staging where cookie auth applies	SameSite/anti-CSRF/origin checks; correct CORS; avoid credentialed wildcard CORS	Cross-origin request cannot write state
9	SSRF / malicious URL import	Link preview/import calls internal/admin/cloud-metadata endpoints	Use an approved internal sentinel in isolated test network	Destination allowlist; DNS/IP validation; redirect validation; egress restrictions	Sentinel and disallowed ranges are never contacted
10	Secrets and insecure CI	Service key/token leaks to browser bundle, logs, repo, or forked PR workflow	Secret scan; inspect bundles/logs/workflow permissions	Server-only secrets; rotation; least-privilege Actions; no privileged execution of fork code	Synthetic marker absent; workflow cannot access secrets on fork PR

Debug flow

1. **Classify and contain.** If access to another student's/institution's data is plausible, disable the narrow route/grant or revoke the exposed credential first; preserve evidence.
2. **Capture safely.** Record UTC timestamps, role/tenant, correlation ID, commit/deploy, migration/config version, expected/actual behavior, and sanitized proof. Never copy raw tokens, student records, or production secrets into tickets or chat.
3. **Reproduce with synthetic fixtures.** Model two users and two tenants. Test UI, direct API, RPC, exports, storage, realtime, cache, and background-job paths—not just the screen where it was noticed.
4. **Trace trusted boundaries.** Browser -> API -> validated identity -> tenant/capability decision -> DB/RLS or privileged worker -> output/log/audit event.
5. **Fix cause and siblings.** Search equivalent routes, functions, views, policies, and data copies. A client-side hide, a new UI condition, or a WAF rule is not a complete authorization fix.
6. **Retest independently.** Re-run original and sibling negative tests, positive authorized behavior, fresh/upgraded database migrations, and monitor after deployment.

Incident escalation

Potential unauthorized education-record access, active secret exposure, privilege escalation, or cross-tenant access is a release blocker. Assign an incident commander; preserve evidence; assess scope; rotate/revoke where relevant; involve privacy/legal for contractual and legal-notice decisions. Internal remediation targets are proposed only: critical contain immediately/fix within 24 hours where feasible; high within 7 days; medium 30; low 90.